Laporan Fase 1 — Hardening Awal & Baseline Traffic Normal

Mata kuliah: TEK1314 Keamanan Siber · Kelas A · Kelompok 4

Produk IoT: KABITA — pencatatan berat badan dan pakan kambing

Periode: Minggu 1-7 (penyelesaian lab: 20-22 Oktober 2026)

Peran	Nama	NIM
Lead	Olan Elrai Ramotan Sibagariang	J0404241158
Blue Team	Anggi Permana Putra	J0404241154
Red Team	Raka Syauqi Ferdian	J0404241112
Red Team	Muhammad Zidan	J0404241173

---

1. Ringkasan

Fase 1 membangun fondasi proyek: laboratorium tiga node pada segmen `192.168.4.0/24`, replika backend KABITA, hardening awal, dan baseline traffic normal sebagai pembanding deteksi.

Hasil:

1. Target Node menjalankan **Ubuntu Server 26.04.1 LTS** dengan aplikasi **Nuxt 4 (Nitro)** di port 80 dan **PostgreSQL 18** pada database `kabita`.
2. Data awal: 2 kandang, 6 kambing ber-RFID, 60 baris telemetri (10 hari), 2 token perangkat.
3. Ketiga node saling terhubung; sensor Security Onion menerima trafik segmen lab.
4. Hardening awal: 2 kontrol selesai (B-1, B-2), 1 sebagian (B-3), tanpa memutus layanan (dashboard tetap HTTP 200 dari node penyerang).
5. Baseline terekam: **482 paket**, 452 di antaranya trafik port 80.
6. Enam celah sengaja dipertahankan sebagai sasaran Fase 2 dan sudah dibuktikan bisa ditembus.

2. Arsitektur

Node	OS	IP lab	Peran
Attacker	Kali Linux 2026.2	192.168.4.100	menjalankan serangan
Target	Ubuntu Server 26.04.1	192.168.4.5	KABITA (Nuxt 4, PostgreSQL 18)
Monitoring	Security Onion 2.x	192.168.4.200	sensor pasif

Subnet dan IP sama dengan Minggu 4. Yang berubah hanya Target Node: semula direncanakan Metasploitable2, diganti Ubuntu Server agar replika menyerupai backend IoT nyata dan kontrol hardening bisa dibuktikan.

3. Replika backend KABITA

Lapisan	Teknologi	Port
Aplikasi	Nuxt 4 + Nitro (SSR + API)	80
Runtime	Node.js 22, systemd `kabita.service`	-
Basis data	PostgreSQL 18, database `kabita`	5432 (localhost)
Perlindungan	ufw, fail2ban	-

Endpoint: `/` (dashboard), `/login`, `/api/login`, `/api/kambing`, `/api/ringkasan`, `/api/telemetri` (GET riwayat, POST ingest dengan token perangkat).

Keputusan teknis: tanpa nginx (Nitro langsung port 80), tanpa broker MQTT (ingest lewat HTTP),

tanpa container. Tujuannya satu: lebih sedikit lapisan, lebih sedikit permukaan serangan.

4. Celah yang sengaja dipertahankan

#	Celah	Uji	Ditutup
1	SQL injection pada `/api/telemetri` dan `/api/login`	RT-03	C-2
2	Password plaintext, kredensial `admin/admin123`	RT-02/RT-03	A-1, C-2
3	Token device statis di query string	RT-03	C-3
4	Telemetri tanpa validasi rentang	RT-03	C-3
5	Cookie sesi tanpa tanda tangan	RT-04	A-1, C-1
6	SSH password auth, tanpa TLS	RT-02/RT-01	A-2, C-1

Semua sudah dibuktikan dapat ditembus, bukan asumsi:

```
curl -s -X POST http://127.0.0.1/api/login -H 'Content-Type: application/json' \
  -d '{"username":"admin'\'' --","password":"x"}'
# -> {"ok":true,"user":{"username":"admin","role":"admin"}}

curl -s "http://127.0.0.1/api/telemetri?kambing=1%20OR%201=1&limit=3"
# -> seluruh baris telemetri terbaca
```

5. Hardening awal

Kontrol	Tindakan	Hasil	Status
B-1	matikan ModemManager, snapd, fwupd, multipathd, upower, udisks2	service aktif 24 ke 18	Selesai
B-2	ufw default deny, allow 22 dan 80 (80 hanya dari lab)	`Status: active`, 2 rule	Selesai
B-3	`apt full-upgrade`, unattended-upgrades	10 paket systemd ditahan phased update	Sebagian

Port yang terbuka ke lab hanya 22 dan 80. PostgreSQL hanya `127.0.0.1:5432` sehingga tidak terlihat dari hasil pemindaian.

Uji bahwa hardening tidak memutus layanan, dijalankan dari Attacker Node:

```
HTTP=200
{"jumlah_kambing":"6","rata_berat":"31.3","pakan_hari_ini":"8.78","catatan_hari_ini":"6"}
```

6. Baseline traffic normal

Pengambilan: `sudo tcpdump -i enp0s3 -nn -w ~/baseline.pcap -c 900` di Target Node, sementara Attacker Node menjalankan 15 putaran permintaan dashboard, API kambing, dan ping.

Metrik	Nilai
Total paket	482
Trafik port 80	452
Koneksi baru (SYN)	45
Paket ICMP	30
Dari 192.168.4.100	286
Dari 192.168.4.5	196
Ukuran pcap	186.833 byte

Artefak: `docs/blueteam/evidence/baseline/`. Angka ini menjadi pembanding saat Fase 2: lonjakan koneksi, pola pemindaian, atau request berulang dinilai menyimpang atau tidak terhadap baseline.

7. Kendala dan pembelajaran

Kendala	Penyelesaian
VM tidak saling terhubung	semua NIC lab ke intnet `pbl-kel4`
Instalasi unattended berhenti di konfirmasi	jawab `yes` pada konsol
IP statis di Kali tidak dijawab ARP	pakai `nmcli`, bukan `ip addr add`
Sensor tidak menjawab ARP	`promisc on arp off` bawaan SO, set `arp on`
nginx dan MariaDB hilang saat migrasi stack	replika final tanpa nginx, database PostgreSQL
capture tcpdump di latar belakang mati	jalankan lewat `systemd-run` agar tidak terputus
10 paket tertahan	phased update Ubuntu; dicatat, bukan diklaim selesai

8. Kesiapan Fase 2

7. Sasaran serangan tersedia dan terdaftar (enam celah) beserta kontrol penutupnya.
8. Sensor menerima trafik lab sehingga deteksi dapat diuji.
9. Baseline angka tersedia untuk menilai anomali.
10. Sisa pekerjaan: verifikasi `so-status` (Security Onion 2.x sudah EOL), pencabutan sudo

NOPASSWD sebelum penilaian, dan pelaksanaan tujuh kontrol sisanya pada siklus Purple Team.

Lampiran — artefak

Artefak	Lokasi
Skema IP	`docs/design/ip_plan.md`
Konfigurasi VM	`docs/design/vm_config.md`
Panduan membangun replika	`docs/design/replica_setup.md`
Kode aplikasi	`app/kabita/`
Bukti baseline	`docs/blueteam/evidence/baseline/`
Bukti hardening	`docs/blueteam/evidence/hardening/`
Checklist 10 kontrol	`docs/blueteam/hardening_checklist.md`
Panduan perintah per VM	`docs/checkpoint-pertemuan9.md`